fintrust.

FinTrust Project Master

Transaction Monitoring & Risk Alert Platform

RELEASE 1 | 12 October 2026

Source checkpoint 9e49a2f

Authoritative consolidated documentation. Explicitly separates local verification, historical deployment evidence and pending live gates.

Fictional client: Imbokodo Bank. No real bank adoption or production compliance certification is claimed.

Contents

1. Executive Summary 4

2. Imbokodo Bank Case Study 4

3. Problem Statement 4

4. Product North Star 4

5. Project Scope 5

6. Assumptions and Constraints 5

7. Stakeholders 5

8. Users and Role Separation 5

9. Functional Requirements 6

10. Non-functional Requirements 6

11. Planning and Development Approach 6

12. End-to-End Business Flow 7

13. Transaction Lifecycle 9

14. Risk Monitoring Model 9

15. Risk Scenarios and Rules 9

16. Quarantine and Recovery 10

17. Risk Events 10

18. Alerts 11

19. Analyst Review Workflow 11

20. Accounts and Transaction History 12

21. Insights and Reporting 12

22. Audit and Traceability 13

23. Technical Failure / Retry / DLQ 13

24. AWS Architecture 13

25. Architecture Decisions and Trade-offs 15

26. S3 Storage Model 15

27. PostgreSQL Design 15

28. DynamoDB Role 17

29. Security / IAM / RBAC 17

30. POPIA / Data Governance 17

31. Retention Strategy 18

32. Cost Governance 18

33. AWS Budgets 18

34. Testing Strategy 19

35. CI/CD 19

36. Release Verification 19

37. Challenges and Failures 20

38. Lessons Learned 20

39. Current Deployment State 20

40. Future Roadmap 21

41. AI Investigation Assistant 21

42. References 21

1. Executive Summary

LOCAL VERIFIED

FinTrust is a transaction monitoring and risk investigation platform. It admits CSV files, preserves financial identity and provenance, calculates explainable risk signals and gives authorized staff accountable review workflows. It does not move funds, reverse charges or establish fraud.

Current implementation checkpoint 9e49a2f. Risk investigation is locally verified: 810 regression passed / 1 expected administrator-only skip; 65 affected passed; 64 PostgreSQL 16 passed; both browser gates passed. Prior multi-user checkpoint remains recorded. Current-release cloud integration is pending.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md

2. Imbokodo Bank Case Study

PLANNED

Imbokodo Bank is a fictional client created for this project case study. Its operations team needs to reconcile transaction exports and investigate exceptions without losing the source evidence or confusing invalid data with financial risk.

The case study provides business context, not a claim of a real bank engagement, production adoption or regulatory approval.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

3. Problem Statement

LOCAL VERIFIED

Manual file inspection can overlook invalid rows, repeated source transactions and unexplained risk decisions. Retrying partial processing can duplicate financial records or notifications unless identity and recovery are deliberate.

FinTrust separates data-quality decisions, ledger acceptance, risk assessment, investigation and technical recovery. Every submitted row needs a recorded outcome; technical failure must not silently erase accepted financial activity.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

4. Product North Star

LOCAL VERIFIED

What happened? Why is it risky? What should I do next?

FinTrust helps a Risk Analyst answer these questions quickly, consistently and with evidence. The interface prioritizes Transactions, risk details and Review Queue. Insights and reports support investigation rather than replacing it.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; frontend/release1.html

5. Project Scope

LOCAL VERIFIED

Release 1 covers CSV admission, exact duplicate protection, positive-amount transaction validation, quarantine correction, deterministic scoring, durable review and scoped read/report/audit workflows.

Refund/reversal accounting, foreign-exchange conversion, live account balances, enterprise federation, durable notification inboxes and AI investigation are outside the implemented first release. Local direct processing does not establish cloud transport completion.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/RELEASE1_OPERATIONS.md

6. Assumptions and Constraints

LOCAL VERIFIED

Use synthetic data for practice. Region remains af-south-1. The database is private; no NAT Gateway or public RDS access is part of the approved architecture. Lambda targets Python 3.12 / Linux x86_64.

Amount thresholds operate per transaction currency, with no implied FX normalization. Late arrivals do not retroactively rescore previous transactions. Historical package verification is tied to its exact source and checksum.

Source: docs/RELEASE1_OPERATIONS.md; backend/fintrust/rules.py

7. Stakeholders

PLANNED

The fictional bank operations sponsor owns business scope and approves risk policy. Analysts investigate transactions; Auditors examine evidence; Administrators govern access; Maintainers handle technical recovery.

A data owner must approve retention and disposal. A deployment owner controls account mutations and cost acceptance. These accountability assignments are the intended operating model, not evidence that real organizational appointments exist.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/SECURITY.md

8. Users and Role Separation

LOCAL VERIFIED

Named local users have a stable user ID and immutable username/subject, display name, optional email, role, ACTIVE/DISABLED status, creation time and actual last sign-in time. Legacy user IDs derive deterministically from the existing subject. Unknown historical creation times remain unknown.

Admin creates named records and changes role/status with a mandatory reason and governance audit. Creation does not issue a credential. Private local enrollment uses a hidden prompt, stores only a SHA256 hash, cannot create an identity or change its role/account scope, and cannot silently replace an existing credential. The registry is operator-controlled and ignored by Git; production federation/password authentication remains a separate gate.

Backend checks deny unsupported actions on each request. Analyst investigates, corrects assigned-account quarantine and claims/completes owned reviews. Admin governs users and review assignment, never clears/confirms risk or edits financial evidence. Auditor is read-only with audit access; Maintainer handles technical recovery only. Disable blocks subsequent authentication but preserves identity, ownership and audit. Admin must explicitly reassign unresolved work; no automatic role inheritance.

Admin Users remains a compact table with name, username, explicit role/status, last sign-in and credential readiness. Search filters only the already-authorized registry list; sorting never widens authority. No Datadog assets or proprietary branding are used.

Role	Responsibility
Analyst	Upload, correct quarantine, investigate and decide reviews within scope
Auditor	Read-only scoped evidence, reports and audit
Administrator	User/account governance, oversight and unknown-account cases
Maintainer	Technical diagnosis/recovery; no financial review decisions

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/auth.py

9. Functional Requirements

LOCAL VERIFIED

Record source system/reference, canonical transaction identity, fingerprint, file/batch and row provenance. Reject invalid files; quarantine invalid rows; retain all accepted risk levels.

Expose transaction/risk/review/delivery states, correction lineage and actor-attributed history. Reconcile accepted, quarantined, duplicate, pending and failed outcomes. Prevent blind duplicate notification retries.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md

10. Non-functional Requirements

PENDING VERIFICATION

Private networking, verified TLS, least privilege and account-scoped access are required. Atomic financial commits, immutable evidence, bounded reads and deterministic scoring protect correctness.

Throughput, availability SLA, load capacity and production incident response are not established by functional test counts. No production-grade performance claim is made.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/SECURITY.md

11. Planning and Development Approach

LOCAL VERIFIED

Development uses phased local verification followed by separately approved live account steps. Domain rules and artifacts are frozen before deployment; read-only preflight checks assumptions before writes.

The current sequence is clean structure, audit actual flow, wire lifecycle, prove quarantine recovery, prove risk/alert/review interactions, run full scenarios, then Linux packaging and controlled cloud integration.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/REPOSITORY_STRUCTURE.md

12. End-to-End Business Flow

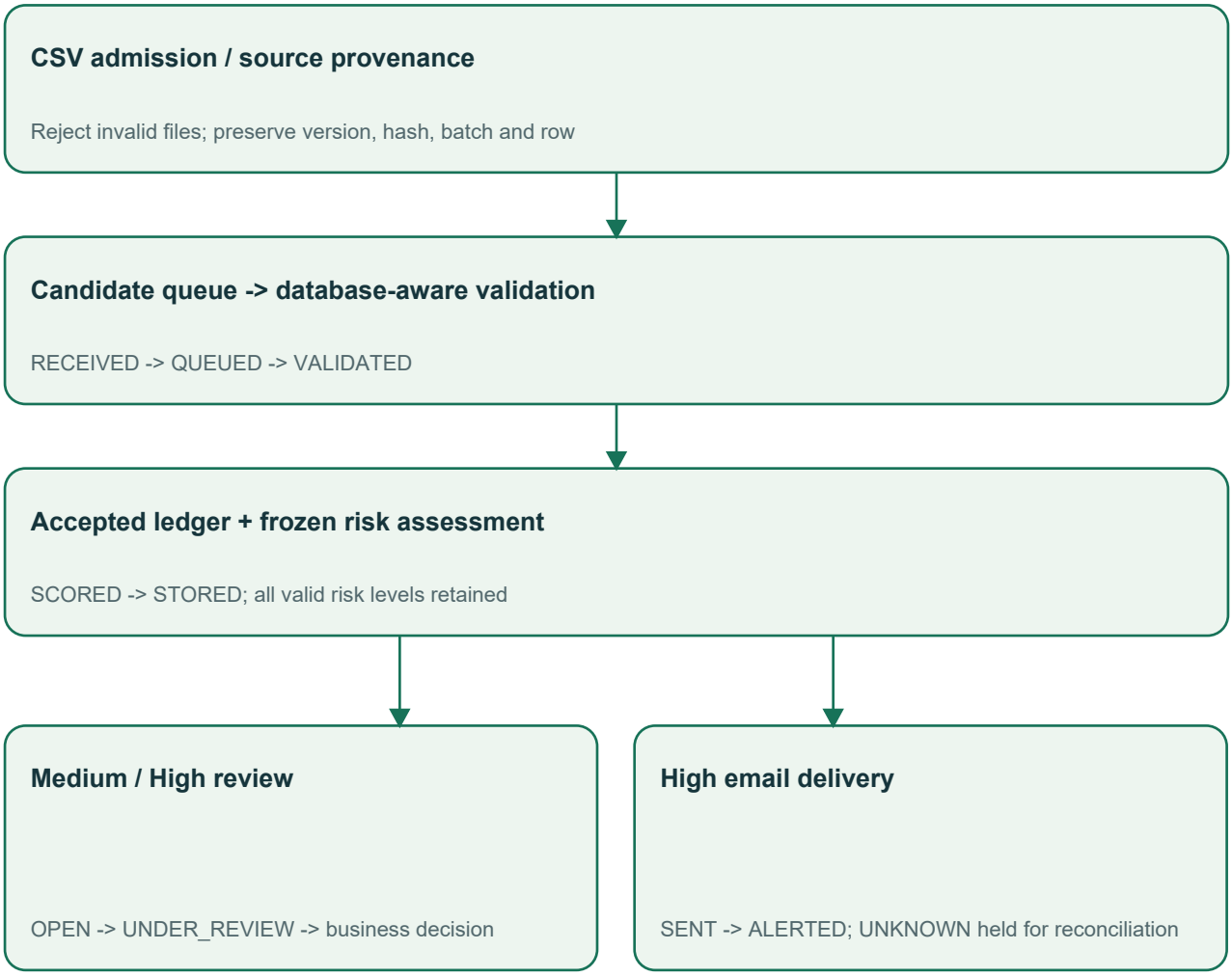
LOCAL VERIFIED

Cloud target: Analyst CSV upload -> input S3 -> ingest parsing/admission -> SQS FIFO candidates -> private consumer database-aware validation -> quarantine OR accepted ledger and frozen scoring -> DynamoDB projection. Medium/High review work is committed independently of High-only email delivery.

The local demonstration uses mocked S3 and a direct SQL consumer helper. It does not prove live FIFO, Streams or SES. The following original process diagrams are historical supporting views; the explicit chronology above and lifecycle contract are authoritative.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

Processing, review and delivery



Invalid rows branch to quarantine. Corrections create new linked occurrences and repeat validation/deduplication. Review does not wait for email.

Supporting detailed diagram: docs/presentation/diagrams/FinTrust_Activity_Diagram.pdf

13. Transaction Lifecycle

LOCAL VERIFIED

Actual processing order: RECEIVED -> QUEUED -> VALIDATED -> SCORED -> STORED. Ingest is outside the VPC; account-aware validation happens in the private consumer after candidate handoff.

Migration 003 adds transaction_lifecycle_events as append-only observations, not a competing mutable status model. Meaningful events record sequence, time and system actor. Human correction/review events retain their authenticated actor. Old rows are not backfilled with invented history.

Risk, review, delivery and processing are separate dimensions. Reads expose provenance and a bounded timeline; timeline_complete=false discloses missing or truncated history. The runtime must not be deployed before migration 003 and its service grants are approved.

Branch	Authority / meaning
Quarantine	Original occurrence terminal; correction creates linked new occurrence
Review	OPEN -> UNDER_REVIEW -> CLEARED / CONFIRMED_RISK / ESCALATED
Recovery	TECHNICAL_FAILURE -> RETRY -> RECOVERED; DLQ needs observed evidence
Projection failure	Financial state remains STORED; pending external projection is recoverable

Source: docs/architecture/TRANSACTION_LIFECYCLE.md; sql/migrations/003_transaction_lifecycle.sql

14. Risk Monitoring Model

LOCAL VERIFIED

Scoring is deterministic and records rule version, score and triggered explanations with the financial outcome. Scores are capped at 100. Low is below 40, Medium is 40 through 69, and High is 70 or above.

HIGH is valid accepted data requiring attention, not quarantine. Every accepted scored transaction has a risk_events record; only Medium/High open routine reviews. Signals are teaching rules, not a validated bank fraud model. Risk outcomes do not authorize money movement.

New frozen results record each triggered rule name, points, explanation, measured value, threshold and context. Signal creation time is the authoritative processed_transactions.processed_at timestamp. Existing historical results are never rescored or assigned invented measurements. Frozen scoring semantics and rule version remain unchanged.

Source: backend/fintrust/rules.py; docs/architecture/FINTRUST_FLOW_AUDIT.md

15. Risk Scenarios and Rules

LOCAL VERIFIED

Frozen Release 1 velocity is more than 5 accepted transactions in the closed 300-second event-time window, including the current transaction. Test 5 versus 6 and the exact window boundary. The 10/11/12-per-hour rule is exploratory and deferred.

For ZAR examples, 49,999.99 and 50,000.00 do not trigger HIGH_AMOUNT; 50,000.01 does. Thresholds apply numerically per currency. Distinct similar charges stay in the ledger and can add a possible-duplicate signal; exact repeats are deduplicated.

Signal	Default points / boundary
HIGH_AMOUNT	30; amount > 50,000
VERY_HIGH_AMOUNT	25 additional; amount > 200,000
TRANSFER	20; transfer type
CROSS_BORDER	15; country differs from ZA / explicit cross-border
MERCHANT_MARKER	20; synthetic highrisk marker
HIGH_VELOCITY	30; accepted count > 5 within 300 seconds
POSSIBLE_DUPLICATE_CHARGE	40; distinct references match facts within 120 seconds

Source: backend/fintrust/rules.py; docs/RELEASE1_E2E_MANIFEST.md

16. Quarantine and Recovery

LOCAL VERIFIED

Original restricted safe evidence, reason code/detail, source version, batch and row remain immutable. Corrections are independently versioned, attributed to the named Analyst and linked to a new occurrence. The existing validator, identity checks and normal processing run again; correction never approves a ledger write directly.

Backend recovery detail exposes OPEN, CORRECTED, REVALIDATION_FAILED, ACCEPTED or REJECTED derived from existing workflow and durable outcome records. No competing status table was added. Failed attempts retain latest reason and every prior correction. Accepted and duplicate resolutions link to the canonical transaction; duplicates do not add a ledger entry.

The detail screen shows original and latest corrected values, correcting Analyst/time, attempt count, outcome and human/system audit timeline. Evidence reads are version-pinned, bounded and account-scoped; incomplete history is explicitly marked. Missing/unknown-account cases remain Admin-visible for access resolution; Admin cannot perform the correction, and Analysts are not given blanket access to unassigned financial data.

Local correction/projection outbox retry remains durable in PostgreSQL. Mock S3 evidence is session-limited, as before; this is not a live retention proof. No credential or sensitive raw payload is logged.

Quarantine now opens a list-preserving recovery drawer with original and corrected values, issue, attempts/outcome, immutable correction history and recorded timeline. Existing account-scoped correction/revalidation actions are reused. Missing/unknown-account cases remain fail-closed under the established access model.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/release_workflow.py; backend/fintrust/workflow_api.py

17. Risk Events

LOCAL VERIFIED

risk_events accompanies every accepted scored transaction, including Low. A risk event is evidence of assessment; it is not synonymous with a High alert or confirmed fraud.

A transaction links its frozen score and rule explanations, risk event, review state, delivery state and source occurrences. Similar charges with distinct identity remain separate ledger records for investigation.

GET /v1/risk-events/{event} assembles account-scoped transaction/source, frozen signals, owner/review, independent alert state, related history and actual audit timeline. Event data stays authoritative in PostgreSQL; delivery claims stay independent in DynamoDB. No competing risk-event state table is introduced.

Investigation drawer retains the queue and follows WHAT HAPPENED / WHEN / WHERE / WHY IS IT RISKY / NEXT STEPS. The displayed last update is the latest review-history change. Compact severity/scenario/assignee/account/status controls, server-side sorting and filtered total/HIGH/active counts operate before pagination. Related history is limited to 20 rows and explicitly reports truncation.

Account baseline is current-ledger, same-currency accepted transactions in the preceding 30 event-time days, strictly before the investigated transaction. It is labelled as contextual data, not the original scoring snapshot; there is no FX aggregation or fabricated comparison. Prior risk/review counts and related transactions come from scoped SQL.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; sql/schema.sql

18. Alerts

LOCAL VERIFIED

High risk enters the email path. Conditional DynamoDB claims coordinate delivery and durable SQL receipts support visibility. SENT evidence permits ALERTED; PENDING, SENDING or UNKNOWN must not be displayed as sent.

A provider timeout may mean the email was sent without a recorded response. UNKNOWN is held for reconciliation, not blindly resent. Exactly-once email is not guaranteed. Medium/High review work remains visible even if delivery fails.

Investigation displays the existing logical HIGH intent and independent PENDING / SENT / FAILED / RETRYING delivery evidence. SENDING and UNKNOWN remain conservative reconciliation states. Missing delivery evidence is not proof of sending; delivery failure does not rollback the ledger or review. SQL legacy receipts and DynamoDB delivery claims remain explicitly distinguished.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/alert_delivery.py

19. Analyst Review Workflow

LOCAL VERIFIED

Each Medium/High review is initially unassigned, with at most one named Analyst owner. Analysts may self-claim an OPEN review; a second claim or stale version is rejected. Only the current owner can make a business decision. Admin may assign, reassign or release an active review with a mandatory reason, never make its decision.

Migration 004 extends the existing transition guard for reassignment/release and adds a reviewer/status/created-time queue index. It reuses reviewer_subject, version and immutable risk_review_history. Escalated reassignment preserves the previous decision, actor, time and resolution; escalation cannot be unassigned. The new owner may resume investigation through the existing transition workflow.

PostgreSQL SELECT FOR UPDATE serializes competing mutations; expected_version rejects stale requests and request IDs support safe replay. A single-host cross-process registry lock and fresh active-role checks prevent a concurrent disable/role change from slipping into a new assignment or human mutation.

My Reviews, Unassigned, All Open, High Risk and Over SLA filters run on the scoped backend before pagination. Age is calculated from creation time. FINTRUST_REVIEW_SLA_SECONDS is optional (60 through 31536000); absent configuration yields an explicit unconfigured result, not an invented business deadline.

POST /v1/reviews/{event}/notes appends an investigation note only for the currently assigned active Analyst in UNDER_REVIEW. Expected version, row lock, request digest and replay protection reuse risk_review_history. The current note projection can change, but each prior note remains immutable in history.

Local additive migration 005_investigation_notes.sql evolves only the existing transition guard to allow a same-owner UNDER_REVIEW note append. It adds no table/column/state. Base -> 001 -> 002 -> 003 -> 004 -> 005 is tested locally; frozen 001-004 files remain unchanged. Current live runner approval does not implicitly include 003-005.

Clear / Confirm Risk / Escalate require notes, actor and resolution evidence. Wrong Analyst, Admin, Auditor and Maintainer cannot decide or append notes. Administration can assign but cannot substitute for Analyst judgment. Existing terminal/escalated recovery and ownership rules remain authoritative.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/workflow_api.py

20. Accounts and Transaction History

LOCAL VERIFIED

Transactions and account history use scoped authorized reads, time and currency context, and stable transaction identity. Stored historical rows without assessment remain Not assessed rather than receiving invented scores.

Customer/account foreign keys protect reference integrity. Unknown accounts are quarantined, not silently created. The balance column is not a real-time banking balance engine; transaction totals are not available funds.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; sql/schema.sql

21. Insights and Reporting

LOCAL VERIFIED

Insights expose scoped SQL aggregates and exact tabular equivalents. Transaction/currency context must remain visible; cross-border activity alone is not suspicious.

Reports UI exports the current authorized query page. Backend scheduled monthly JSON/CSV outputs to S3 exist but are not a complete generated-report catalogue in the UI. A monthly summary is not a full ledger archive.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/report.py

22. Audit and Traceability

LOCAL VERIFIED

Trace from source system/reference and fingerprint through file SHA256, batch, row, canonical tx_id, frozen assessment and human decision. Ingestion outcomes and reconciliation disclose duplicates and pending failures.

Append-only lifecycle and review histories prevent silent overwrites. Local governance records are not CloudTrail or enterprise identity proof. Evidence is sanitized: no tokens, credentials or secret values belong in logs or screenshots.

User governance preserves named actor, reason and before/after metadata in existing versioned receipts. Review history exposes claim, reassignment, release and decision actions. Correction history records human submission and authoritative system revalidation/ledger outcomes. Disable and display-name changes do not rewrite past actors or delete audit.

Source: docs/architecture/TRANSACTION_LIFECYCLE.md; docs/SECURITY.md

23. Technical Failure / Retry / DLQ

LOCAL VERIFIED

A failed projection after financial commit leaves the SQL ledger STORED. Replay uses immutable identity and the frozen result, then marks RECOVERED only after durable completion. RETRY_REQUESTED by an operator is different from an executed worker retry.

FIFO batch processing stops at the first failure and reports failed plus unprocessed IDs. The transaction DLQ and async failure queues hold technical failures; they are not quarantine. Automatic lifecycle DLQ transport/reconciliation remains deferred.

A SQL outage before occurrence registration cannot create a SQL audit event. Worker transport evidence remains authority; the API never fabricates missing observations.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md; docs/OPERATIONS.md

24. AWS Architecture

PENDING VERIFICATION

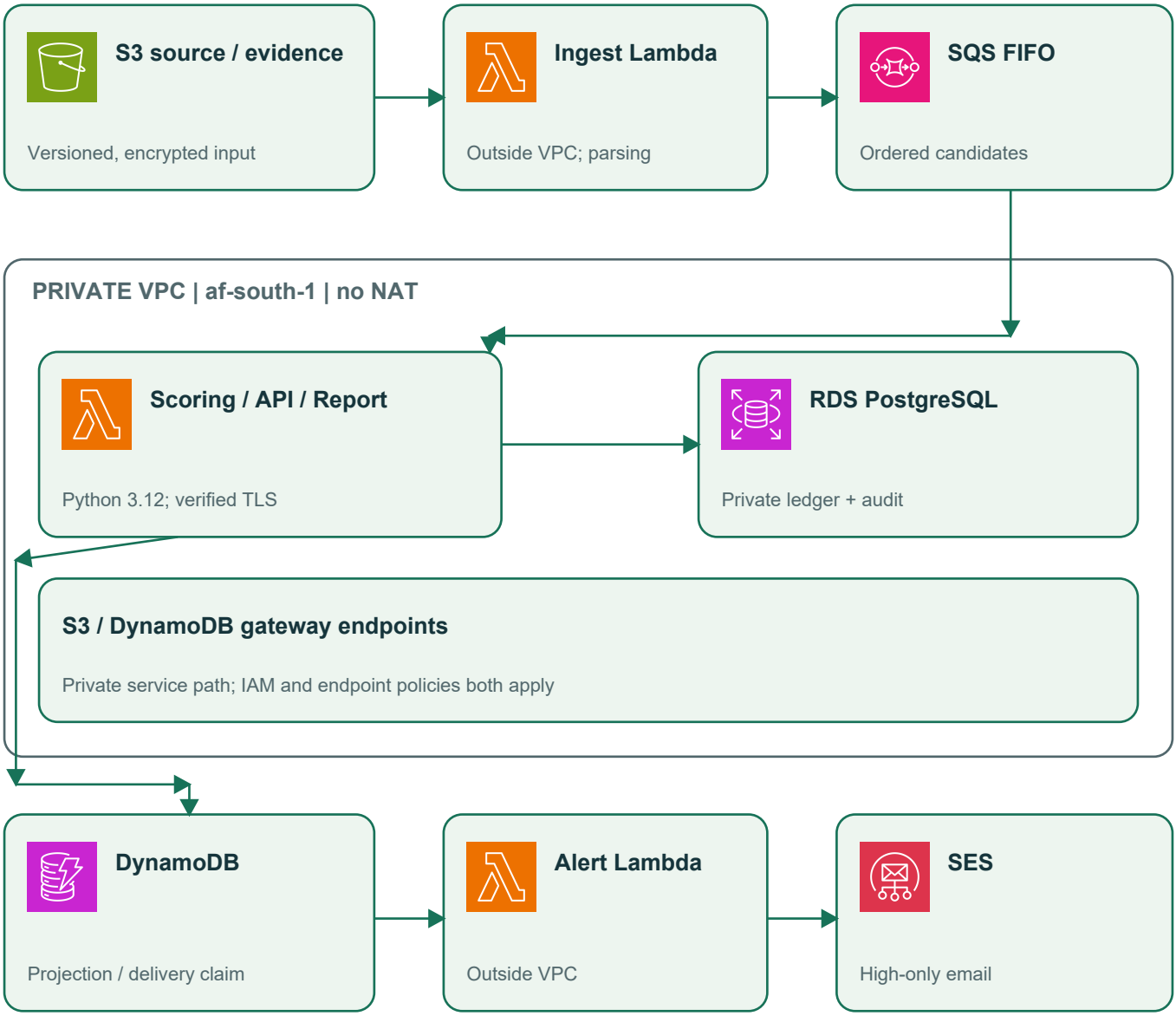
af-south-1 is preserved. Private application subnets reach the database security group on TCP 5432 only from the approved application security group. S3 and DynamoDB gateway endpoints support the private workers without NAT.

Ingest and alert run outside the VPC because their selected cloud handlers do not require SQL. Scoring, API and report are private SQL clients. SES and trigger wiring need separate live verification.

Official AWS icons in the retained diagrams identify services; they do not prove that current-release wiring is deployed. Diagram colors reflect their historical presentation checkpoint. Temporary Secrets Manager migration networking was deleted after read-only preflight.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/diagrams/README.md

Architecture - official AWS icons



Official AWS icons retained in docs/diagrams/aws-icons/. Foundation historically verified; current-release wiring pending. Temporary migration interface endpoint is not standing infrastructure.

Supporting detailed diagram: docs/presentation/diagrams/FinTrust_AWS_Architecture.pdf

25. Architecture Decisions and Trade-offs

LOCAL VERIFIED

FIFO preserves per-account processing order; immutable IDs and SQL uniqueness address replay beyond FIFO deduplication windows. PostgreSQL owns financial truth; DynamoDB serves immutable projections and conditional delivery state.

No NAT avoids standing cost and narrows egress. Private bootstrap credentials require an explicit Secrets Manager path. A temporary interface endpoint supported the historical read-only preflight and was cleaned up afterward.

Single-AZ RDS, disabled consumers and small capacity prioritize controlled development cost over high availability. Adoption, scale and HA need independent production review.

Original FinTrust brief remains authoritative. Research validates implementation quality, not project scope. No AML expansion, funds authorization, account freezing or autonomous fraud/regulatory decisions were added. Industry suggestions outside the brief remain future scope.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; infrastructure/PRIVATE_RDS_MIGRATION_PLAN.md

26. S3 Storage Model

LOCAL VERIFIED

Raw input, quarantine and report buckets separate operational data classes. Stage 2 uses private, versioned buckets with SSE-KMS, secure-transport policy and a shared regional customer-managed key. Object version/checksum pinning ties package evidence to the exact uploaded artifact.

Quarantine safe payloads remain sensitive. Retained bucket/key resources and noncurrent versions can continue costing money after stack deletion. Current reports do not replace archival exports.

Source: infrastructure/storage.py; docs/OPERATIONS.md

27. PostgreSQL Design

LOCAL VERIFIED

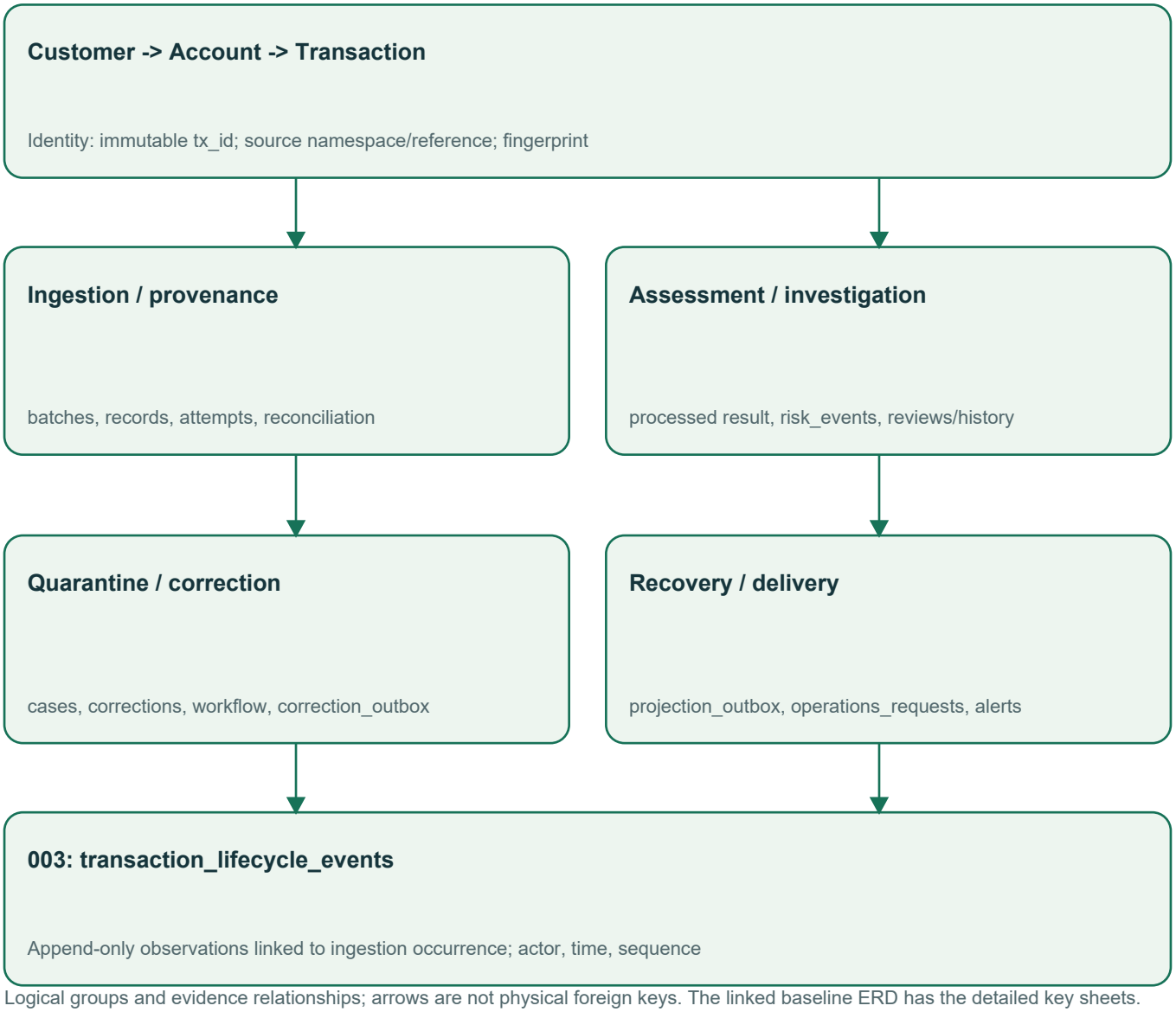
Authoritative base: the checksum-bound section of sql/schema.sql before Additive identity hardening, rendered by tools/render_release1_base.py with sql/bootstrap/release1-base-manifest.json. Six base tables include Phase 1 alert upgrades. Apply verified identity 001, workflows 002 and lifecycle 003 in order. Catalog prerequisites reject drift. Synthetic seeds are not required for live bootstrap.

Core domains: customers/accounts; transactions and frozen processed_transactions; ingestion batches/records/attempts/reconciliation; quarantine/corrections/outbox; risk events/reviews/history; alerts; projection and operations recovery.

The 17-table baseline ERD predates 003, which adds transaction_lifecycle_events. Migration 004 changes only review guard/index; no new tables. Its checksums preserve earlier history and validate the current catalog. Latest live preflight found no base schema. Live bootstrap, 001/002/003/004/005 and grants remain unapproved.

Source: sql/schema.sql; sql/migrations/003_transaction_lifecycle.sql; infrastructure/RELEASE1_DATABASE_BOOTSTRAP_REVIEW.md; docs/architecture/TRANSACTION_LIFECYCLE.md; sql/migrations/004_review_assignment.sql

Current data domains and lifecycle extension



Logical groups and evidence relationships; arrows are not physical foreign keys. The linked baseline ERD has the detailed key sheets.

Supporting detailed diagram: docs/presentation/diagrams/FinTrust_ERD.pdf

28. DynamoDB Role

LOCAL VERIFIED

DynamoDB holds immutable transaction projections for stream-driven delivery and conditional alert claims. It does not replace the PostgreSQL financial ledger or analyst review authority.

SQL projection_outbox coordinates retries when the secondary write fails after commit. The current foundation uses on-demand billing, AWS-owned encryption and no automatic TTL for this delivery state. Mocked tests do not prove live stream processing.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; infrastructure/messaging.py

29. Security / IAM / RBAC

LOCAL VERIFIED

Separate execution roles, scoped actions/resources, account authorization and service-specific database grants limit exposure. IAM rds-db:connect grants connection authority, not SQL table privileges. Database clients require TLS verify-full with the bundled RDS CA.

RDS storage uses AWS-managed aws/rds encryption; the Stage 2 S3 key is not automatically the RDS key. Managed master credentials are for reviewed bootstrap, not application environment variables or browser payloads.

Future 003 rollout must give scoring INSERT/SELECT plus sequence USAGE, API SELECT only, and no UPDATE/DELETE on lifecycle audit. The fixed live runner still supports only its reviewed phases. No broad grants should mask missing permissions.

This phase changes local backend RBAC only. No AWS policy, credential, resource, deployment or activation changed. Controlled local bearer enrollment is a verification mechanism, not enterprise identity management. Existing scopes and fail-closed financial access remain authoritative.

Source: docs/architecture/TRANSACTION_LIFECYCLE.md; docs/SECURITY.md; infrastructure/iam/DEPLOYER_DESIGN.md

30. POPIA / Data Governance

PLANNED

Names and identity numbers are direct identifiers; accounts and transaction details are linkable personal financial information. Synthetic examples, restricted reads, encryption and sanitized evidence reduce exposure.

This document records design controls, not a legal opinion or certification of POPIA compliance. A data owner must approve purposes, access, retention, disposal and incident procedures before real personal data is processed. No legal retention period is asserted.

Source: docs/data_governance.md; docs/SECURITY.md

31. Retention Strategy

PLANNED

Current processing logs use 14-day retention; queues have finite retention and need investigation before expiration. The current DynamoDB delivery state has no TTL. Retained S3 versions/quarantine and RDS backups/snapshots require explicit disposal authorization.

The design proposes 12 months in the ledger, closed-period full exports in S3 Standard for 3 years and Glacier Flexible Retrieval for 7 years. This is not a legal determination and the export/purge job is not implemented. The archive/ transition after 1,095 days does not apply to monthly/ report summaries.

Older governance files describe different assumptions. Current templates and these stated limits take precedence; never delete ledger rows without reconciliation, checksum/count proof, restore test and approved policy.

Source: docs/OPERATIONS.md; infrastructure/storage.py

32. Cost Governance

PENDING VERIFICATION

Standing costs include RDS compute and 20 GiB gp3 storage, the S3 customer-managed KMS key and retained data/backups/logs. Lambda, SQS, DynamoDB, SES, requests and transfer add usage-dependent charges.

No NAT is proposed. Temporary interface endpoints charge per endpoint/AZ-hour and usage; historical temporary preflight endpoint deletion is recorded on 11 October 2026. Retained artifacts/logs may still incur storage charges.

Prices in old stage plans are dated estimates, not current bills. No fresh pricing or Cost Explorer query was performed for consolidation. Re-price af-south-1 and confirm credits/allowances before each spending approval.

Source: infrastructure/DEPLOYMENT_BOOTSTRAP.md; docs/OPERATIONS.md; docs/EVIDENCE/05-rds/release1-temporary-preflight-cleanup-result.md

33. AWS Budgets

PENDING VERIFICATION

Budgets is an early-warning control, not a spending cap. Deployment approval should identify the budget owner, monthly threshold, recipients and response procedure. Missing notification evidence must remain pending rather than be inferred from a budget-first plan.

Before activation, check account/region, budget notification delivery, concurrency, report scheduling and endpoint/RDS cleanup ownership. This documentation task performs no budget creation, billing lookup or notification test.

Source: infrastructure/BUDGET_FIRST.md; docs/EVIDENCE/01-budget

34. Testing Strategy

LOCAL VERIFIED

Historical lifecycle checkpoint 7397f22: 756 passed, 1 skipped, zero failures; focused 62 and PostgreSQL 16 lifecycle 21. The administrator-only skip has separate prior PG16 evidence. Current multi-user verification is recorded below; neither result proves live migration 003/004/005 privileges.

Tests cover identity, threshold boundaries, immutable outcomes, rejected/quarantined rows, correction lineage, partial-write recovery, delivery claims, role/account authorization and browser workflows. Local mocks intentionally avoid AWS. Counts establish tested behavior, not availability, live service permissions or performance.

Multi-user phase: 789 regression passed / 1 administrator-only skip; 27 focused passed; 130 affected checks passed; 48 PostgreSQL 16 passed; browser passed. Focused coverage includes immutable correction lineage, failed/successful/duplicate revalidation, named onboarding and disable/reactivate, role separation, concurrent claims, wrong-owner denial, assignment replay/scope, escalated recovery and browser role/action visibility. Evidence: docs/EVIDENCE/12-e2e/multi-user-operations/.

Risk investigation: 16 new backend tests plus a real loopback browser gate; 65 affected tests; 64 on disposable PostgreSQL 16; full regression 810 passed / 1 expected administrator-only skip. Evidence: docs/EVIDENCE/12-e2e/risk-investigation/. No live AWS transport occurred.

Source: docs/EVIDENCE/12-e2e/transaction-lifecycle/verification-summary.json; tests/test_transaction_lifecycle.py

35. CI/CD

LOCAL VERIFIED

GitHub Actions provides exact-source Linux Python 3.12 packaging/import and disposable PostgreSQL 16 gates. Dependency wheels, handlers, native PostgreSQL imports, CA loading, archive contents and checksum are tied to the release manifest.

Build/test workflows do not authorize deployment. A push and current-source CI run require their own scope. Historical green runs and artifacts are preserved; source movement and lifecycle changes require a fresh gate before promotion.

Source: infrastructure/LINUX_CI_GATE.md; .github/workflows

36. Release Verification

PENDING VERIFICATION

Freeze source commit, build inputs, package digest, manifest, Linux imports and test proof together. Verify uploaded VersionId and checksum before a change set. Never reuse an old Linux result for changed application source.

Current checkpoint is local verified, not a frozen deployable artifact. Live schema bootstrap and migration 003 privileges, authenticated API, cloud queue/stream paths, SES, alarm delivery and recovery exercise remain gates. Approval is scoped and sequential.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; infrastructure/HARDENED_RUNTIME_RELEASE.md

37. Challenges and Failures

LOCAL VERIFIED

Live Stage 3 exposed missing DescribeEngineDefaultParameters and retained named parameter-group cleanup concerns. Stage 5 exposed provider-side tagged log creation authorization requirements that static validation could not prove; one-variable diagnostics narrowed the cause.

The read-only RDS preflight proved private verified TLS connectivity and found missing base schema, preventing an unsafe incremental migration. Quota constraints required a separately approved one-shot activation with finally restoration and revocation.

Local lifecycle verification caught retry/recovery state defects; financial storage and processing failure now remain separate. Historical outputs stay in EVIDENCE, including failures rather than only successes.

Source: infrastructure/STAGE5_PERMANENT_FIX.md; docs/EVIDENCE/05-rds/release1-live-readonly-alternative-preflight-result.md; docs/architecture/TRANSACTION_LIFECYCLE.md

38. Lessons Learned

LOCAL VERIFIED

A valid CloudFormation template does not prove live provider authorization. Simulated IAM context does not guarantee identical runtime context. Change one variable and capture both failure and recovery evidence.

Preflight must confirm the actual database baseline. Retained named resources can collide with fresh CREATE attempts. Disabled concurrency is a deployment safety control, not evidence of runtime correctness.

Financial acceptance, risk, review and notification delivery must remain independent. Never hide gaps with fabricated timestamps, UI-only labels, silent resets or indiscriminate permission broadening.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md

39. Current Deployment State

PENDING VERIFICATION

Historical evidence/user-verified stages: network, S3/KMS, RDS PostgreSQL and DynamoDB/SQS stacks CREATE_COMPLETE. Historical ingest deployment/diagnostics are distinct from the current source. No AWS inventory or mutation occurred in this consolidation.

The 11 October 2026 live read-only check used PostgreSQL 16.15 with TLS verify-full and found the application base schema missing. Cleanup then removed temporary runner/network stacks and billable endpoint, preserving the five existing stacks and retained evidence.

Current application source is local verified. Complete cloud integration, current-source Linux packaging and live SQL bootstrap are pending. Do not call the whole application deployed.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/EVIDENCE/05-rds/release1-live-readonly-alternative-preflight-result.md; docs/EVIDENCE/05-rds/release1-temporary-preflight-cleanup-result.md

40. Future Roadmap

PLANNED

Next: focused Analyst Workbench / Dashboard review; investigation workflow is now locally verified. Keep frozen deterministic rules and independent delivery/review outcomes. No AI or unrelated frontend redesign was introduced.

After local closure: current Linux artifact gate, separately reviewed base bootstrap and 001/002/003/004/005 privilege/catalog chain, controlled live integration and recovery evidence. HA, federation, accounting extensions, archival automation and production capacity review are later scope.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

41. AI Investigation Assistant

PLANNED

PLANNED / NOT IMPLEMENTED. A future assistant could summarize existing authorized evidence and explain deterministic signals, with sources and human approval. It must not change ledger identity, authorize funds movement or decide confirmed fraud automatically.

No model integration, autonomous investigation, accuracy evaluation or production data transfer exists in the current release. Privacy, access boundaries, audit, quality and cost require a separate approved design.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

42. References

LOCAL VERIFIED

Scope authority is the original user-supplied FinTrust brief. Current flow/lifecycle contracts, SQL, frozen rules, templates and evidence establish implementation status. Online sources validate engineering choices without redefining requirements. Historical narrative is subordinate to current evidence.

The document inventory classifies every authored Markdown/text/PDF. Active deployment/tooling contracts remain supporting references. Historical evidence remains unchanged; superseded clean narrative is archived where safe.

Regenerate both PDFs with python tools/build_project_docs.py after editing docs/source/project-master.json and project-progress.json. Rendering dependencies are reportlab and PyMuPDF. Update explanatory material in Master, status/history in Progress, and actual proof in EVIDENCE.

DECISION: Single owner with row lock and version | SOURCE: https://www.postgresql.org/docs/16/explicit-locking.html | WHY IT APPLIES: Concurrent staff must not overwrite ownership | HOW FINTRUST USES IT: SELECT FOR UPDATE plus expected_version and immutable history.

DECISION: Server-side role, ownership and account checks | SOURCE: https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html | WHY IT APPLIES: The brief requires accountable separation of duties | HOW FINTRUST USES IT: Deny unsupported actions and validate owner/account/active role.

DECISION: Controlled local credential enrollment | SOURCE: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html | WHY IT APPLIES: Named sign-in must not expose credentials or imply production federation | HOW FINTRUST USES IT: Private prompt, unique opaque credentials, hashes only, disable checks.

DECISION: Actor and outcome audit without secrets | SOURCE: https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html | WHY IT APPLIES: Investigations require attributable history | HOW FINTRUST USES IT: Reuse append-only SQL history and versioned governance receipts; no credential logging.

DECISION: list-preserving investigation drawer, compact filters and visible triage | SOURCE: https://docs.datadoghq.com/security/cloud_siem/triage_and_investigate/investigate_security_signals/ | WHY IT APPLIES: Analysts need evidence and next steps without losing queue context | HOW FINTRUST USES IT: Adapt interaction principles to transaction risk, with original branding and backend-enforced ownership; no copied icons, wording or pixel layout.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md; docs/source/documentation-inventory.json; https://www.postgresql.org/docs/16/explicit-locking.html; https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html; https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html; https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html; https://docs.datadoghq.com/security/cloud_siem/triage_and_investigate/investigate_security_signals/; sql/migrations/005_investigation_notes.sql; backend/fintrust/investigation.py; docs/EVIDENCE/12-e2e/risk-investigation/verification-summary.json